



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-9198 IBM Langflow Code Injection KEV Exploitation Priority

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-19
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-9198 IBM Langflow Code Injection KEV Exploitation Priority - CVE / Vulnerability Threat Intelligence Report

Published: 2026-08-19 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-9198 IBM Langflow Code Injection KEV Exploitation Priority

1. Executive Summary

Langflow-like AI/workflow services often sit near credentials, API keys, model connectors, and internal automation. A KEV-listed unauthenticated code-injection issue should be handled as a rapid containment and exposure-reduction item, especially where developer tools are internet reachable.

Lost Boys Cyber assesses this item as a same-day remediation priority because the vulnerability is associated with CISA Known Exploited Vulnerabilities reporting or direct vendor patch-cycle visibility. Defenders should verify asset ownership, internet exposure, compensating controls, and patch state before treating the issue as closed.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-9198
Product / Component	IBM Langflow
Weakness	Code injection enabling unauthenticated remote code execution according to CISA KEV text
Severity	Critical / KEV-prioritized
Affected Versions	Validate against vendor advisory and local inventory
Fixed Versions	Validate against vendor advisory and installed build numbers
Disclosure / KEV Context	Current daily coverage window: 2026-08-19
Exploitation Status	Added to CISA KEV on 2026-08-04 with active exploitation evidence

3. Source Review & Confidence

Source	Contribution	Confidence
CISA alert: adds three KEVs	CISA names CVE-2026-9198 IBM Langflow Code Injection among three KEV additions.	High
CISA KEV Catalog	Catalog text describes unauthenticated attackers achieving full remote code execution on Langflow.	High
IBM security advisories	Vendor advisory source for product-specific remediation validation.	Medium

Confidence is highest for KEV/vendor facts and medium for environment-specific exposure until asset owners confirm deployment scope.

4. Vulnerability Details

The reported weakness affects IBM Langflow. The practical defender concern is unauthorized access or code execution on a high-value service that may bridge external users, internal data, privileged automation, or collaboration workflows. Because public exploitability or KEV status changes remediation priority, teams should not wait for opportunistic scanning telemetry before acting.

5. Attack Scenarios

- Internet-exposed instance is probed after public KEV/advisory circulation and exploited before normal monthly patch windows complete.
- Attacker uses compromised credentials or edge proxy access to reach an internal instance and exploit the vulnerable component for privilege expansion or data access.
- Exploitation is chained with web-shell deployment, token theft, or scheduled-task persistence after initial access.

6. Threat Landscape & Exploitation Status

CISA KEV inclusion means the vulnerability has evidence of exploitation in the wild. Attribution, exact victimology, and exploit maturity may vary; the operationally safe assumption is that scanning and opportunistic exploitation will accelerate after advisory publication.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing service	Highest priority because exploitation can occur without VPN or internal foothold.
Externally proxied internal app	Reverse proxies, SSO gateways, and WAFs can obscure vulnerable backend versions.
Privileged developer/admin workflow	Compromise can expose secrets, automation tokens, or downstream systems.
Patched asset with residual artifacts	Validate no web shells, unauthorized accounts, or suspicious jobs remain.

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Vulnerability Management	Identify all IBM Langflow assets and verify version/build against vendor guidance.
Critical	Infrastructure	Patch or isolate exposed instances; remove internet exposure where not required.
High	SOC	Review logs for exploitation indicators, anomalous authentication, suspicious process creation, and outbound callbacks.
Medium	App Owners	Confirm backups and recovery procedures before emergency maintenance windows.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Unexpected child processes from application service accounts	EDR process telemetry	Catch post-exploitation command execution.
New files in web/application directories	File integrity / EDR file events	Identify web shells, droppers, or modified

		application artifacts.
Authentication anomalies around patch window	Identity logs	Identify bypass, spraying, or suspicious admin access.

9.2. Sigma / Detection Rule

```

title: Suspicious Application Server Post Exploitation Activity
status: experimental
logsource:
  product: windows
  category: process_creation
detection:
  selection_parent:
    ParentImage|contains:
      - w3wp.exe
      - tomcat
      - java.exe
      - python.exe
  selection_child:
    Image|endswith:
      - cmd.exe
      - powershell.exe
      - bash
      - sh
      - curl.exe
      - wget.exe
  condition: selection_parent and selection_child
level: high

```

9.3. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("w3wp.exe", "java.exe", "python.exe", "tomcat.exe")
| where FileName in~ ("cmd.exe", "powershell.exe", "bash", "sh", "curl.exe", "wget.exe")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName

```

10. Threat Hunting

10.1. Hunt Hypothesis

If exploitation occurred, application service identities or web/application processes will spawn command interpreters, write unusual files, or initiate outbound network connections shortly before or after vulnerability disclosure.

10.2. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("w3wp.exe", "java.exe", "python.exe", "tomcat.exe")
| where RemoteUrl !endswith ".microsoft.com" and RemoteIPType == "Public"
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Connections=count() by DeviceName, InitiatingProcessFileName, RemoteUrl, RemoteIP

```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Publicly reachable vulnerable applications are the primary risk scenario.
T1059	Command and Scripting Interpreter	Post-exploitation often uses shell or scripting tools.
T1505.003	Server Software Component: Web Shell	Web app exploitation can lead to server-

		side persistence.
--	--	-------------------

12. Validation / Lab Testing

No exploit reproduction was performed in this automated daily run. Validation completed: source triage, KEV/vendor source review, detection/hunt content creation, render verification, and publication checks.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Asset Owners	Confirm whether vulnerable product is deployed and exposed.
Critical	Patch Team	Apply vendor fixes or isolate until patched.
High	SOC	Run the included process/network hunts over the last 14-30 days.
Medium	IR Lead	Preserve logs for exposed systems before emergency rebuilds.

14. References

- [CISA alert: adds three KEVs](<https://www.cisa.gov/news-events/alerts/2026/08/04/cisa-adds-three-known-exploited-vulnerabilities-catalog>) — CISA names CVE-2026-9198 IBM Langflow Code Injection among three KEV additions.
- [CISA KEV Catalog](<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>) — Catalog text describes unauthenticated attackers achieving full remote code execution on Langflow.
- [IBM security advisories](<https://www.ibm.com/support/pages/bulletin/>) — Vendor advisory source for product-specific remediation validation.